COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Password Attacks

Mestre CyberSec · **Aula 2.4 — Password Attacks** (7:15) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Password attack: password spraying (UMA senha comum MUITOS usuários — evita lockout); credential stuffing (senhas VAZADAS reusadas); brute force (todas as combinações — rápido mas detectável); dictionary (lista de palavras); rainbow table (hash pré-computados — MORTO pelo SALTING

💡 Highlights que a prova CompTIA cobra

- Password spraying: 1 senha fraca contra muitos usuários (discreto)
- Brute force = tentar tudo; dictionary = lista de palavras
- Rainbow table = hash pré-computada — MORTA pelo SALTING
- Reusa de senha vazada em outros sites = credential stuffing

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'single weak password tried against many accounts' = password spraying
- 'pre-computed hash table' = rainbow table (defesa: salting)

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Password Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Pulverização de Senhas (N/A)

Ataque que tenta uma única senha fraca comum contra muitas contas de usuário diferentes, muitas vezes respeitando limites para evitar bloqueio de conta.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'uma senha fraca contra muitas contas' = password spraying. Não confunda com brute force/dictionary, que focam uma única conta.*

• Preenchimento de Credenciais (N/A)

Uso de pares usuário/senha vazados de um serviço para autenticar em outros serviços, explorando a reutilização de senha.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'senhas vazadas reutilizadas em outros sites' = credential stuffing; difere de spraying porque usa pares usuário/senha vazados.*

• Ataque de Força Bruta (N/A)

Tentar todas as combinações possíveis de caracteres até encontrar a senha correta; pode ser online ou offline.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'todas as combinações possíveis'. É barulhento/detectável online e pode causar lockout.*

• Ataque de Dicionário (N/A)

Uso de uma lista de palavras comuns, senhas vazadas e variações para adivinhar senhas, em vez de tentar todas as combinações possíveis.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'lista de palavras' ou 'wordlist'. Não tenta todas as combinações como o brute force.*

• Tabela Arco-Íris (N/A)

Tabela pré-computada de hashes de senhas usada para reverter rapidamente hashes de senhas sem sal.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'tabela de hashes pré-computados' = rainbow table; defesa principal: salting.*

• Salting (N/A)

Adicionar um valor aleatório único a cada senha antes do hash, armazenado junto ao hash, para que senhas iguais produzam hashes diferentes.

⚠️ ***Armadilha CompTIA:*** *Gatilho: salting torna rainbow tables inúteis. Não impede brute force, mas aumenta o custo; senhas iguais geram hashes diferentes.*

• Hash de Senha (N/A)

Representação criptográfica unidirecional de uma senha usada para verificação; se roubada, pode ser atacada offline.

⚠️ ***Armadilha CompTIA:*** *Gatilho: hash não é criptografia; ataques offline usam hashes roubados. Salting e key stretching são defesas.*

• Alongamento de Chave (N/A)

Aplicar hashing repetido e salgado para tornar a verificação de senha mais lenta e encarecer ataques de força bruta ou dicionário.

⚠️ ***Armadilha CompTIA:*** *Gatilho: bcrypt, PBKDF2, Argon2 = key stretching. Defesa contra brute force/dicionário, especialmente offline.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Força Bruta vs. Dicionário vs. Ataque Híbrido

🏠 **Analogia Intuitiva:** Imagine tentar abrir um cofre mecânico de 4 algarismos. O Ataque de Força Bruta é o sujeito exaustivo e metódico que testa todas as combinações matemáticas possíveis do universo: 0000, 0001, 0002... até 9999; ele tem certeza absoluta que vai abrir o cofre um dia, mas se a senha tiver 15 caracteres misturados ele levará 300 anos para terminar. O Ataque de Dicionário é o assaltante prático que testa apenas as palavras e combinações que as pessoas mais usam no dia a dia: 'admin', '123456', 'senha', 'brasil', 'amor'; ele termina em 2 segundos, mas se a senha for 'X#9kQ' ele nunca vai adivinhar. O Ataque Híbrido é o criminoso inteligente que une os dois mundos: ele pega palavras comuns do dicionário e aplica as malandragens que os humanos sempre fazem para tentar parecer seguros (troca 'a' por '@', 'e' por '3', e coloca o ano ou uma exclamação no final, testando 'P@ssw0rd2024!').

🔍 **Causa Raiz / Por que foi criado:** Humanos sofrem de fadiga de memória e escolhem senhas previsíveis baseadas em palavras conhecidas e substituições triviais de caracteres. Computadores e placas de vídeo (GPUs) modernas conseguem processar centenas de bilhões de tentativas de hash por segundo, quebrando senhas fracas ou baseadas em dicionários quase instantaneamente.

🛡️ **Visão do Auditor de GRC:** Adequar a política corporativa de senhas ao padrão moderno NIST SP 800-63B: priorizar o comprimento da senha (comprimento mínimo de 15 a 16 caracteres em vez de rotação obrigatória frequente de 30 dias); implementar verificação ativa contra listas de senhas vazadas conhecidas (Password Blacklisting); e exigir autenticação multifator (MFA) para neutralizar a perda de senhas estáticas.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker attempts every single mathematical permutation of characters until finding the correct password'. Resposta: Brute Force. Trigger: 'attacker feeds a text file of words and commonly used passwords into a cracking tool'. Resposta: Dictionary Attack. Trigger: 'attacker modifies dictionary entries with numbers and character substitutions such as P@ssw0rd1!'. Resposta: Hybrid Attack.

📌 Pulverização de Senha (Password Spraying) vs. Credential Stuffing

🏠 **Analogia Intuitiva:** Imagine um prédio corporativo com 1.000 salas trancadas. Se você parar na porta da Sala 101 e tentar 5 chaves erradas seguidas na mesma fechadura, o alarme de segurança vai disparar e a fechadura travará por meia hora (política de bloqueio de conta). No Password Spraying (Pulverização de Senha), o ladrão pega UMA ÚNICA chave comum que muita gente preguiçosa usa (ex: 'Empresa@2024') e testa uma única vez na Sala 1, uma vez na Sala 2, uma vez na Sala 3... até a Sala 1.000. Como ninguém errou mais de uma vez na mesma porta, nenhum alarme toca na guarita e o ladrão acha 5 salas abertas! Já no Credential Stuffing (Recheio de Credenciais), o ladrão compra na internet uma lista de 50.000 pares de 'e-mail e senha' vazados do cadastro de um aplicativo de entregas de comida e coloca um robô para testar esses mesmos e-mails e senhas nos portais bancários e e-mails corporativos daquelas pessoas, aproveitando-se do fato de que as pessoas repetem a mesma senha em tudo.

🔍 **Causa Raiz / Por que foi criado:** O Password Spraying explora a fragilidade das políticas tradicionais de bloqueio, que contabilizam tentativas por conta individual e não detectam uma tentativa única espalhada horizontalmente por milhares de contas. O Credential Stuffing explora o hábito universal dos usuários de reutilizar a mesma senha em dezenas de sites pessoais e profissionais.

🛡️ **Visão do Auditor de GRC:** Para Password Spraying: implantar ferramentas de análise comportamental de usuários (UEBA) que identifiquem picos anômalos de autenticações globais com a mesma senha; monitoramento de telemetria de login em tempo real; e MFA obrigatório. Para Credential Stuffing: integração contínua com serviços de monitoramento de credenciais vazadas (Threat Intelligence feeds / Have I Been Pwned enterprise API) para forçar a redefinição preventiva de contas corporativas comprometidas em vazamentos externos.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker attempts a single popular password (e.g., Summer2024!) across hundreds or thousands of user accounts to avoid triggering account lockout policies'. Resposta: Password Spraying. Trigger: 'attacker uses automated scripts to test a massive list of stolen username and password pairs obtained from an external third-party breach against an organization's login portal'. Resposta: Credential Stuffing.

📌 Tabelas Arco-Íris (Rainbow Tables) vs. Salt Criptográfico (Salting)

🏠 **Analogia Intuitiva:** Uma Rainbow Table é como um guia telefônico gigantesco onde alguém já passou anos calculando com antecedência o resultado de milhões de hashes: 'se o hash for 5f4dcc3b, a senha original era password'. O invasor não precisa gastar tempo calculando nada; ele apenas olha a tabela pronta e acha a senha na hora. O Salt (sal) é como o cozinheiro adicionar uma pitada de tempero aleatório, exclusivo e secreto diferente em cada prato antes de servir: mesmo que duas pessoas peçam exatamente a mesma receita básica ('123456'), o tempero secreto exclusivo faz os dois pratos resultarem em códigos químicos completamente diferentes. O guia telefônico pré-calculado do invasor não tem essa combinação aleatória e se torna 100% inútil!

🔍 **Causa Raiz / Por que foi criado:** Funções de hash comuns (como MD5 ou SHA-1) são determinísticas: a mesma palavra sempre gera exatamente o mesmo hash. Em bancos de dados sem salt, atacantes utilizam Rainbow Tables pré-computadas baseadas em cadeias de redução para reverter milhões de hashes roubados em segundos sem gastar processamento de CPU.

🛡️ **Visão do Auditor de GRC:** Auditar as rotinas de autenticação e armazenamento de credenciais da empresa. Exigir o uso de funções modernas de derivação de chaves resistentes a GPUs (Key Stretching functions como Argon2, bcrypt ou PBKDF2), com geração obrigatória de um Salt criptograficamente aleatório e único para cada usuário, contendo no mínimo 16 a 32 bytes de comprimento.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'precomputed lookup table containing pre-calculated hashes used to crack passwords rapidly by trading storage space for computation time'. Resposta: Rainbow Table. Trigger: 'cryptographic defense that appends a unique random string to each password before hashing to defeat rainbow table attacks and ensure identical passwords produce distinct hashes'. Resposta: Salt / Salting.

📌 Políticas de Bloqueio de Conta (Account Lockout) vs. Vulnerabilidade de Negação de Serviço (DoS)

🏠 **Analogia Intuitiva:** Imagine uma agência bancária com uma regra intransigente: 'Se alguém errar a chave da porta da frente 3 vezes seguidas, a agência fecha as portas de aço automaticamente e ninguém trabalha pelo resto do dia'. Um vândalo mal-intencionado passa na calçada às 7h da manhã, digita a chave errada de propósito três vezes na porta de todas as salas da diretoria em 15 segundos e vai embora rindo. Resultado: a política de segurança que foi criada para proteger a empresa acabou paralisando o banco inteiro e causando um desastre operacional autoinfligido!

🔍 **Causa Raiz / Por que foi criado:** Políticas de bloqueio rígido (ex: bloquear a conta após 3 ou 5 tentativas inválidas consecutivas) foram desenvolvidas para impedir ataques online de força bruta. Contudo, atacantes perceberam que podem usar scripts simples para errar senhas propositalmente nas contas de administradores e executivos, transformando o mecanismo de segurança em um vetor de Negação de Serviço (Denial of Service - DoS).

🛡️ **Visão do Auditor de GRC:** Alinhando-se às diretrizes NIST SP 800-63B, o auditor de GRC deve recomendar a substituição de políticas de bloqueio rígido por controles mais resilientes: limitação de taxa adaptativa (Rate Limiting / Throttling com atraso progressivo exponencial entre erros), desafios de CAPTCHA, autenticação baseada em risco (analisando IP, geolocalização e reputação do dispositivo) e MFA obrigatório.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'aggressive account lockout threshold allows an attacker to intentionally lock legitimate user accounts by submitting repeated failed authentication attempts'. Resposta: Denial of Service (DoS) vulnerability. Solução recomendada pela CompTIA / NIST: CAPTCHA, progressive delays (throttling), and risk-based authentication instead of hard lockouts.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Tentativa exaustiva de todas as permutações matemáticas de caracteres até encontrar a senha correta	**Ataque de Força Bruta (Brute Force Attack)**
Uso de uma lista pré-compilada de palavras e senhas comuns alimentada em ferramentas automatizadas de quebra	**Ataque de Dicionário (Dictionary Attack)**
Atacante testa uma única senha comum (ex: 'Verão2024!') em milhares de contas para não estourar o limite de lockout	**Pulverização de Senha (Password Spraying)**
Testar massivamente pares de e-mail e senha vazados de um serviço externo contra o portal de login corporativo	**Recheio de Credenciais (Credential Stuffing)**
Tabela pré-calculada contendo milhões de hashes usada para quebrar senhas instantaneamente por busca direta	**Tabela Arco-Íris (Rainbow Table)**
Inclusão de uma cadeia de caracteres aleatórios e exclusivos na senha antes do hash para neutralizar tabelas arco-íris	**Salt Criptográfico (Cryptographic Salting)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança vê logs de autenticação em que um único IP de origem tentou a senha Summer2024! contra 300 contas de usuário diferentes. Cada conta recebeu apenas um login com falha, e nenhuma conta foi bloqueada. As tentativas continuaram a cada 45 minutos com uma senha comum diferente. Qual ataque de senha melhor corresponde a esse comportamento?

A) Credential stuffing usando credenciais de um vazamento de terceiros

B) Password spraying para evitar limites de bloqueio de conta

C) Ataque de força bruta offline contra hashes de senha capturados

D) Consulta de rainbow table contra hashes de senha sem salt

QUESTÃO 2 · CENÁRIO DE EXAME

Funcionários de uma empresa relatam logins VPN não autorizados de locais desconhecidos. A investiga��ão mostra que o atacante usou uma lista de endereços de e-mail e senhas obtidas de um vazamento não relacionado em uma rede social. Alguns logins tiveram sucesso porque os funcionários reutilizaram suas senhas pessoais no trabalho. Qual ataque ocorreu?

A) Ataque de dicionário

B) Password spraying

C) Credential stuffing

D) Ataque de força bruta

QUESTÃO 3 · CENÁRIO DE EXAME

Um testador de penetração extrai hashes de senha de um aplicativo legado que usa MD5 sem salt. Em vez de enviar tentativas de login, o testador usa um mapeamento pré-computado muito grande de valores de hash para senhas em texto claro e recupera várias senhas rapidamente. Qual técnica está sendo usada?

A) Ataque de rainbow table

B) Password spraying

C) Key stretching

D) Credential stuffing

QUESTÃO 4 · CENÁRIO DE EXAME

Um desenvolvedor está atualizando o armazenamento de senhas de um aplicativo. A equipe de segurança quer garantir que dois usuários que escolherem a mesma senha não produzam o mesmo hash armazenado, e que tabelas de consulta pré-computadas não possam ser reutilizadas contra o banco de dados. Qual mudança o desenvolvedor deve implementar?

A) Aplicar uma política de expiração de senha a cada 90 dias

B) Exigir autenticação multifator para todos os usuários

C) Configurar bloqueio de conta após três tentativas falhas

D) Adicionar um valor aleatório único a cada senha antes de gerar o hash

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa precisa armazenar hashes de senha para um aplicativo interno de alto valor. O arquiteto de segurança quer que o processo de hash permaneça lento e exigente em recursos mesmo em hardware moderno, para que a adivinhação offline de cada senha leve muito mais tempo. Qual técnica deve ser selecionada?

A) Key stretching com bcrypt ou PBKDF2

B) Prevenção de password spraying

C) Detecção de credential stuffing

D) Geração de rainbow table

QUESTÃO 6 · CENÁRIO DE EXAME

Um atacante captura um banco de dados de hashes de senha de um servidor e então usa uma ferramenta que testa sistematicamente todas as combinações possíveis de letras, números e símbolos até encontrar o texto claro correto para uma conta de administrador. Que tipo de ataque é este?

A) Ataque de dicionário

B) Credential stuffing

C) Ataque de força bruta

D) Password spraying

QUESTÃO 7 · CENÁRIO DE EXAME

Durante uma avaliação de aplicativo web, um testador usa uma lista contendo senhas comuns, estações do ano e variações do nome da empresa para adivinhar senhas de usuários. O testador testa a lista contra um único nome de usuário conhecido até encontrar uma correspondência. Qual ataque está sendo realizado?

A) Ataque de rainbow table

B) Ataque de dicionário

C) Ataque de força bruta

D) Password spraying

QUESTÃO 8 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros permite que usuários se autentiquem em um portal interno. Atacantes tentam repetidamente uma senha comum em muitas contas de funcionários, esperando entre as tentativas para que cada conta permaneça abaixo do limite de bloqueio. Qual controle mitiga mais diretamente esse ataque específico sem depender apenas do bloqueio de conta?

A) Autenticação multifator

B) Aumentar o comprimento máximo da senha

C) Desativar o histórico de senhas

D) Armazenar senhas com criptografia reversível

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização descobre que várias contas de usuário foram comprometidas porque funcionários usaram as mesmas senhas em sistemas corporativos e sites pessoais que depois foram vazados. Os atacantes simplesmente reutilizaram os pares de nome de usuário e senha vazados. Qual controle adicional impediria melhor que isso tivesse sucesso no futuro?

A) Requisitos de complexidade de senha

B) Intervalos mais curtos de expiração de senha

C) Autenticação multifator

D) Salts únicos no banco de dados de hashes de senha

QUESTÃO 10 · CENÁRIO DE EXAME

Um auditor de segurança descobre que um banco de dados armazena hashes de senha SHA-256 sem salt. O auditor alerta que atacantes poderiam recuperar muitas senhas de uma vez se o banco de dados fosse roubado. Qual ataque de senha é mais diretamente mitigado ao adicionar um salt único a cada senha antes de gerar o hash?

A) Password spraying

B) Credential stuffing

C) Ataque de dicionário

D) Ataque de rainbow table

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Password spraying para evitar limites de bloqueio de conta

Correto: password spraying tenta poucas senhas comuns em muitas contas para permanecer abaixo dos limites de bloqueio. O cenário mostra uma tentativa por conta em 300 contas, com senhas comuns repetidas, não pares de credenciais vazadas, força bruta por conta ou busca offline de hashes. Credential stuffing usaria pares usuário/senha vazados; brute force faria muitas tentativas por conta; rainbow table é um ataque offline com hashes pré-computados.

Questão 2: Alternativa C — Credential stuffing

Correto: credential stuffing usa pares de usuário e senha roubados de outros vazamentos e os reutiliza contra o alvo, contando com a reutilização de senhas. O cenário envolve um vazamento não relacionado e logins bem-sucedidos por senhas reutilizadas. Password spraying usa senhas comuns em muitas contas; dictionary usa listas de palavras; brute force testa todas as combinações.

Questão 3: Alternativa A — Ataque de rainbow table

Correto: uma rainbow table é um mapeamento pré-computado de hashes para senhas em texto claro, eficaz contra hashes sem salt. Salting ou key stretching com salts únicos derrotam tabelas pré-computadas. Password spraying e credential stuffing são ataques de credenciais online, não buscas offline em hashes pré-computados.

Questão 4: Alternativa D — Adicionar um valor aleatório único a cada senha antes de gerar o hash

Correto: salting adiciona dados aleatórios únicos a cada senha antes do hash, então senhas iguais produzem hashes diferentes e tabelas pré-computadas não podem ser reutilizadas. Expiração de senha, MFA e bloqueio de conta são controles úteis, mas não alteram a unicidade do hash nem impedem o reuso de rainbow tables contra hashes roubados.

Questão 5: Alternativa A — Key stretching com bcrypt ou PBKDF2

Correto: key stretching, como bcrypt, PBKDF2 ou Argon2, torna o hash intencionalmente lento com iterações ou fatores de trabalho, encarecendo a adivinhação offline. Password spraying e credential stuffing são métodos de ataque, não defesas. Geração de rainbow table é ataque; salting sozinho evita pré-computação, mas key stretching adiciona custo computacional.

Questão 6: Alternativa C — Ataque de força bruta

Correto: brute force testa sistematicamente todas as combinações possíveis, podendo encontrar senhas curtas ou fracas, mas é lento e ruidoso. Dictionary usa uma lista focada de palavras; credential stuffing reutiliza pares vazados; password spraying tenta poucas senhas comuns em muitas contas para evitar bloqueio.

Questão 7: Alternativa B — Ataque de dicionário

Correto: um ataque de dicionário usa uma lista curada de senhas prováveis e variações, geralmente mais rápido que brute force exaustivo contra senhas escolhidas por humanos. Rainbow tables exigem hashes capturados; brute force testa todas as combinações; password spraying ataca muitas contas com poucas senhas.

Questão 8: Alternativa A — Autenticação multifator

Correto: MFA mitiga mais diretamente o password spraying, pois mesmo que a senha comum seja adivinhada para uma conta, o atacante ainda precisa de um segundo fator. Comprimento e complexidade de senha podem ajudar, mas não impedem diretamente o padrão do ataque; histórico de senhas e criptografia reversível são controles ruins. Bloqueio de conta isolado pode ser contornado espalhando tentativas abaixo do limite em muitas contas.

Questão 9: Alternativa C — Autenticação multifator

Correto: MFA impede que credential stuffing tenha sucesso apenas com usuário e senha vazados, porque o atacante não consegue fornecer o segundo fator. Complexidade e expiração podem reduzir senhas fracas, mas não impedem a reutilização de credenciais válidas vazadas; salting protege hashes armazenados, não a autenticação online com credenciais vazadas válidas.

Questão 10: Alternativa D — Ataque de rainbow table

Correto: rainbow tables dependem de valores de hash pré-computados. Um salt único por senha altera a saída do hash, tornando tabelas pré-computadas ineficazes. Password spraying e credential stuffing são ataques online com credenciais adivinhadas ou vazadas; ataques de dicionário ainda podem tentar adivinhar, mas o salt especificamente derrota consultas pré-computadas.